

SEE ALSO Newsletter of November 27, 2023

[doc. web n. 9954220]

Provision of October 12, 2023

Register of provisions

n. 473 of October 12, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by

Prof. Pasquale Stanzione, President, Prof.

Ginevra Cerrina Feroni, Vice President, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing "Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter "Code");

HAVING REGARD TO Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor for the protection of personal data, approved by resolution No. 98 of April 4, 2019, published in G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web n.9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the organization and functioning of the office of the Guarantor for the protection of personal data, on www.gpdp.it, doc. web n.1098801;

Rapporteur Prof. Pasquale Stanzione;

PREMISED

1. The complaint and the investigative activity

The Authority received a complaint from Ms. XX in

which she reported repeated accesses, by some

colleagues between 2019 and 2020, to her health file

from the Local Health Authority of Lodi (hereinafter "Authority").

From the documentation attached to the complaint and acquired in the records, it appears that Dr. XX and Dr. XX made the aforementioned accesses, respectively, to "know which human resources could be counted on to carry out our work and care for patients in the best possible way" as "the quickest method was to know the result of the nasopharyngeal swab for Covid-19" present in the health file of the colleagues and therefore also of the complainant (see note from the Authority dated XX, prot. n. XX attached to the complaint).

With specific reference to the access made by Dr. XX, from the documentation attached to the complaint and acquired in the records, it appears that she accessed the complainant's file within the "Telecovid Zcare program" "with the aim of verifying the quality and effectiveness of the service provided also through statistical reprocessing of the characteristics of the assisted population, the care pathway, and the outcomes of the monitoring" (see note from the Authority dated XX, prot. n. XX attached to the complaint). According to what was stated by the Authority in the records, "the consents for such a project, including any reprocessing for possible publication, were collected simultaneously with the enrollment in Zcare and the

names of the patients were entered into a database from which the enrollment was followed."

Regarding the tracking operations of accesses to the health file carried out by the aforementioned Authority, it highlighted that "the accesses" of "all those healthcare figures who during the indicated period (2019/2020) were authorized to access the operational units in which (the complainant) transited" "are not tracked."

In relation to what was reported, the Office requested information from the aforementioned Authority with note dated XX (prot. n. XX), to which the latter responded with note dated XX (prot. n. XX) in which it was represented, in particular, that:

- "it was not possible to find any consent in paper form granted by Ms. XX" and that, considering the pandemic context, it was highlighted that there was a "mixing of human, work, and pandemic management relationships";
- the accesses to the complainant's health file were dictated by "behavioral modalities aimed at balancing as much as possible the need to ensure attention to the personal needs expressed by the complainant and at the same time the complete, coinciding dedication in managing a global emergency, never experienced before";
- that the aforementioned accesses were made for the

performance of "institutional tasks of public interest in the field of public health" as per Article 9 of the Regulation;

- "it can be stated that there was an implicit consent."

In relation to the findings of the aforementioned investigative activity, the Office, with act n. XX of XX, notified the Authority, pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for data of the individual, in order to ensure the continuity of care and the protection of public health during the emergency period."

In light of the above, the Office has contested that the configuration of the health dossier chosen by the Company, even following the health emergency due to Covid-19, was carried out in violation of the basic principles of data processing as set out in Articles 5, paragraph 1, letters a), b), c), and f), 9, and 32 of the Regulation. The violation of the aforementioned provisions makes the administrative sanction provided for in Article 83, paragraph 4, letter a) and paragraph 5, letter a) of the Regulation applicable.

By note dated XX (prot. n. XX), the Company submitted defensive writings, reiterating what had already been represented in the documents and highlighting, in particular, that:

- the processing related to "access to the data of Ms. R.C. by colleagues" "is partly mandatory (with a legal basis in Article 9, paragraph 2, letters h and i, that is, with reference to the nature of the public functions performed and the emergency period in which the events took place) and partly optional (as far as it specifically pertains to responding to the requests for attention and 'care' of the interested party)";

- "The emergency context is deemed decisive, not only — it is hoped — as a possible 'mitigating factor', but legally to characterize the peculiar role that this ASST plays, and even more so has played during that period: namely that of a public health company, the only point of reference for the entire Province - even in relation to the Lombardy Region and the Health Protection Agency of Milan — for the provision of health services to citizens, both at the hospital and territorial levels";

- "the events occurred in a hospital Hospice, in the 'very first' period of the 'very first' 'red zone'";

- "From the first results of the swabs, 50% of the OSS and 75% of the nurses tested positive, and therefore the indications were to immediately suspend from service the infected personnel and place them in home isolation, notifying the competent doctor of the isolation that had occurred." "Thus, very often they sought help from their colleagues present in the Department, to know the outcome of their swabs before obtaining the result in the health dossier or from the Competent Doctor." "This behavior — dictated not only by the concrete fear of having contracted an almost completely incurable disease - was absolutely necessary, both to know an 'eventual positivity' for themselves and for their family but also for the desire to remain in operational contact with the work team, both at home and in the hospice, which had to be managed day by day to maintain the service." "The exchange of information about the swabs among colleagues, absolutely voluntary, and indeed - as stated - requested by the operators themselves, therefore guaranteed both the knowledge of the outcome to the interested party and the concrete possibility of keeping the two services of the operational unit open, and precisely thanks to these efforts and this availability we were the only operational unit that remained continuously open in the Casalpusterlengo facility throughout the pandemic period";

- "The organization of hospital shifts during that Covid emergency period cannot absolutely be equated to the ordinary organization of shifts by any employer, at any time"; "Therefore, 'knowing which human resources to rely on to carry out our work and care for patients in the best possible way' meant safeguarding the vital interest of thousands of people";

- "The processing of data by the Company was therefore, on the part of the employer, absolutely 'necessary for the execution of a task of public interest or connected to the exercise of public powers with which the data controller is invested (Article 6, paragraphs 1, letter e) 2 and 3, and Article 9, paragraph 2), letter g) of Regulation (EU) 2016/679)."

- "Furthermore, reference is made to the Decree-Law of March 7, n. 18, Article 17-bis (Provisions on the processing of personal data in the emergency context) which has given Entities, such as this ASST, the possibility to 'carry out processing [...] also relating to the data of the individual, in order to

ensure the continuity of care and the protection of public health during the emergency period."

****Articles 9 and 10 of Regulation (EU) 2016/679, which are necessary for the performance of the functions assigned to them in the context of the emergency caused by the spread of Covid-19**;**

- "The consent (of the claimant) was collected on the CCE Galileo application on April 8, 2020, by Dr. Inzoli" and a copy of the status of the consent (active) visible on the DSE is attached to the report."

"However, it should be noted that, despite further searches, unfortunately, no paper documents supporting the granting of consent were found";

- For TeleCovid "The procedure was well defined and required the signing of consent in paper form and the separate archiving of the same, with the delivery of a pulse oximeter by our facility if not available to the patient. The information sheet we used is available in the procedure and was regularly signed," however "no paper copy was found in the archive," which could "have been mistakenly delivered to the Patient";

- "This ASST is not unaware that the treatments mentioned should have been carried out "adopting appropriate measures to protect the rights and freedoms of the data subjects" — such as consent, where required by law, as in the case of the DSE." "In fact, there were no apparent possibilities in the company procedures of that period for derogations regarding the necessity of requesting consent";

- "It is the course of events, as described, that leads to the conclusion that: in the first case (TeleCovid) consent was given orally (as attested by the statements on record) during the relevant period; in both cases, the will of the claimant can nonetheless be traced back to her unequivocal positive actions, unfortunately, in the second case, the paper document that attested to it was lost"; "The claimant has indeed taken unequivocal positive actions regarding the fact that the personal data concerning her were subject to processing: actions that can therefore legitimately support the validity of the consent";

- Following the facts under examination "the following awareness communications were adopted and disseminated to the Service Managers and employees:

- Note dated XX, regarding: "Obligation to acquire consent for the activation of the DSE (Galileo)" attached n. 10 to note prot. n. XX of XX;

- Note: "Compliance with the Guidelines on health dossiers and the provisions regarding Privacy Consent," prot. n. XX of XX, (attached n. 2 to this communication) which was: either disseminated to all company operators (so-called "transmission everyone") or personally sent to the company service managers (Directors of SC and Coordinators), via email, with a request for each recipient to confirm reading.

- It was also decided to enhance training on the subject, by including an afternoon training event for each module of the ongoing company privacy course, aimed at involving an even greater number of healthcare operators in the training meetings, as requested by them;

- An activity of monitoring on self-certifications of access is planned through the extraction of access lists and sample verification of actual necessity. Medical staff have been informed that all accesses are tracked and may be subject to checks";

- In the highlighted notes, the Company reminded the need to ensure compliance with the guidelines of the Guarantor on health dossiers of June 4, 2015.

To the defensive writings, a note from the Director of the company information systems was attached, stating that:

"the most significant actions performed by the operators are tracked in the application database";

"For the registration of accesses, it is necessary to distinguish between accesses performed by the ward personnel responsible for the patient and accesses to historical data or relating to

"non-responsible" patients. In the first case, only modification or insertion actions are tracked, and not simple accesses; in the second case, a set of information concerning user references, the reason for access, date, and time of request is recorded";

"Consultation accesses for non-responsible patients are recorded in the database and are subject to periodic control checks";

"To make the verification more regular and immediate, an automatic extraction mechanism for access logs has been activated and sent via email to the medical management of the hospital hub and the director of the SCD PSS";

"Each attempt to access "non-responsible" patients triggers a warning banner indicating the

non-accessibility of the dossier. The content of the banner will be further modified to include a note stating that access is tracked and subject to checks and that accesses not conforming to the intended purposes are punishable under the law.”

****2. Outcome of the investigative activity.****

****2.1. Legal framework of reference.****

Preliminarily, it is stated that the processing of personal data must take place in compliance with the applicable regulations on personal data protection and, in particular, the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 (hereinafter, the “Regulation”) and Legislative Decree No. 196 of June 30, 2003 (Code regarding the protection of personal data – hereinafter, the “Code”).

Data must also be collected for determined, explicit, and legitimate purposes, and subsequently processed in a manner that is not incompatible with such purposes.

****Purpose and nonetheless, “adequate, relevant, and limited to what is necessary for the purposes for which they are processed” (principles of purpose limitation and data minimization - art. 5, par. 1, lett. b) and c) of the Regulation)****

With particular reference to the matter at hand, it is emphasized that personal data must be “processed lawfully, fairly, and transparently” (principle of “lawfulness, fairness, and transparency” and “in a manner that ensures an adequate level of security (...), including protection against unauthorized or unlawful processing” (principle of “integrity and confidentiality”)” (art. 5, par. 1, lett. a) and f) of the Regulation).

The Regulation further provides that the data controller must implement “appropriate technical and organizational measures to ensure a level of security appropriate to the risk,” taking into account, among other things, “the nature, scope, context, and purposes of the processing, as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons” (art. 32 of the Regulation).

With reference to the processing subject to the aforementioned complaint, the Authority has adopted the “Guidelines on Health Dossier - June 4, 2015” (Provision of 4.6.2015, published in G.U. 164 of July 17, 2015, available at [www.gdpd.it doc web n. 4084632](http://www.gdpd.it/doc/web/n.4084632)), in which a preliminary framework of safeguards was identified to outline specific guarantees and responsibilities, as well as necessary and appropriate measures and precautions to ensure the protection of citizens concerning the processing of health data relating to them.

Pursuant to the Regulation, if the processing is necessary for reasons of public interest in the field of public health, such as protection against serious cross-border health threats, as indicated by the aforementioned Company, it must be carried out based on Union or Member State law that provides for appropriate and specific measures to safeguard the rights and freedoms of the data subject, in particular professional secrecy (art. 9, par. 2, lett. i)).

Since the declaration of the state of emergency decided by the Council of Ministers on January 31, 2020, in accordance with the provisions of the European Regulation for pursuing public interest reasons in the field of public health (cited art. 9, par. 2, lett. i) of the Regulation), many urgent regulatory acts have been adopted, which contain provisions also related to the processing of health data carried out in the context of the aforementioned health emergency, resulting from a delicate balance between public health needs and those related to the protection of personal data.

In particular, with specific reference to the regulations adopted in our country, pursuant to the aforementioned art. 9, par. 2, lett. i) of the Regulation, to address the aforementioned health emergency, it is stated that art. 17-bis of d.l. n. 18/2020 has not and could not have derogated from the regulations on data protection, which, it is emphasized, is based on European Regulation 2016/679; this national legislative provision has provided for some simplifications in the processing and communication of personal data among different data controllers only when they are indispensable for the performance of activities related to the management of the ongoing health emergency and, in any case, in compliance with the principles of art. 5 of the Regulation, adopting appropriate measures to

protect the rights and freedoms of the data subjects.

The processing of personal data related to the management of the aforementioned health emergency must therefore take place in compliance with the existing regulations on the protection of personal data and, in particular, with the principles and limits applicable to processing, as set out in art. 5 of the Regulation, according to which data must be processed lawfully, fairly, and transparently concerning the data subject ("lawfulness, fairness, and transparency"), "collected for specified, explicit, and legitimate purposes" ("purpose limitation"), and, in any case, "adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed" (principle of data minimization).

In this regard, as already indicated to the Company in the note of XX, the Authority has repeatedly highlighted the need to evaluate the applicability of the provisions of the aforementioned art. 17-bis of d.l. n. 18 of 2020, on a case-by-case basis, drawing the attention of data controllers operating in the health sector to the fact that not all health data processing can be attributed to this provision (see, among many, note of June 9, 2020, doc. web n. 9429175).

With specific reference to the case at hand, reference is made to the provision adopted by this Authority on November 10, 2022, which sanctioned a health company that had modified the visibility rules of the health dossier during the emergency period, thus allowing all healthcare personnel to consult the health dossiers of any patient who had been treated by the Company, regardless of whether the person accessing the dossier was involved in the care pathway of the data subject and whether the latter had expressed consent to the processing of data carried out through the dossier (doc. web n. 9819792).

****2.2. The consent of the data subject****

In the aforementioned 2015 Guidelines, the Authority specified that the health dossier, constituting... the purpose of legal assessments) or for any other purpose not directly related to the care of the patient.

2.4. Data minimization and purpose limitation

The principle of data minimization requires that only the personal data necessary for the purposes of the treatment are processed. This means that the health data included in the health dossier must be strictly relevant to the specific clinical events concerning the data subject. The treatment of personal data must also be limited to the purposes for which the data were collected, ensuring that they are not further processed in a manner incompatible with those purposes.

2.5. Rights of the data subject

The data subject has the right to access their personal data, to request rectification or erasure of their data, and to restrict or object to the processing of their data. These rights must be guaranteed by the health professional and the health facility, ensuring that the data subject is informed of their rights and how to exercise them.

2.6. Accountability and compliance

The health professional and the health facility are responsible for ensuring compliance with the applicable data protection regulations. They must implement appropriate technical and organizational measures to protect personal data and demonstrate accountability in their data processing activities.

In conclusion, the treatment of personal data in the context of health care must be conducted in accordance with the principles of legality, necessity, and proportionality, ensuring that the rights of the data subjects are respected and protected at all times.

****Assessment of Work Fitness or for the Issuance of Certifications Necessary for Granting Permits or Licenses**** (see point 6)

The Authority has indeed repeatedly emphasized that, given the optional nature of the dossier and the informational incompleteness (see right to erasure) of this tool, it cannot be used for purposes related to the management of organizational and administrative needs of the data controller, even in cases where, as in the present case, the same entity assumes both the role of employer and that of the

health authority responsible for the care of the individual concerned (see Decision of May 26, 2022, web doc. no. 9791909).

It is also noted that, in general, the employer may process the personal data of workers (Article 4, No. 1, of the Regulation), including data related to “special categories,” in the management of the employment relationship, if the processing is necessary “to comply with a legal obligation to which the data controller is subject” (Articles 6, paragraph 1, letter c), 9, paragraphs 2, letter b) and 4; 88 of the Regulation) or when it is “necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller” (Article 6, paragraphs 1, letter e), 2 and 3, and Article 9, paragraph 2, letter g), of the Regulation; Articles 2-ter and 2-sexies of the Code, in the text prior to the amendments made by Decree Law No. 139 of October 8, 2021).

More specifically, the processing of data related to the health of employees can only be legitimately carried out when it is “necessary to fulfill the obligations and exercise the specific rights of the data controller or the data subject in the field of labor law and social security and social protection, to the extent authorized by Union law or the laws of Member States or by a collective agreement under the laws of Member States, in the presence of appropriate safeguards for the fundamental rights and interests of the data subject” (Article 9, paragraphs 2, letter b), and 4, of the Regulation; see also, Article 88, of the Regulation and recitals 51-53).

In this context, it is highlighted that, in line with what has been clarified since the “Guidelines on the processing of personal data of workers for the purposes of managing the employment relationship in the public sector” (Provision of June 14, 2007, No. 23, web doc. no. 1417809), the principles of which are still considered valid, the employer may process, in compliance with data protection principles and applicable sector regulations, personal data related to the health of employees only for the purposes and under the conditions provided for by law or upon specific indication from the competent doctor, the only subject legally authorized to perform health surveillance tasks, in compliance with the specific limits and prerequisites established by the regulations on health and safety in the workplace (Legislative Decree No. 81 of April 9, 2008). This separation of roles is further confirmed by the structure of the Regulation, which considers separately the processing necessary for the purposes of “occupational medicine” (Article 9, paragraphs 2, letter h), and 3 of the Regulation), within which the function of the competent doctor provided for by national legislation falls, as opposed to those carried out by the employer to fulfill their obligations “in the field of labor law,” including those established by regulations on “health and safety at work” (see combined provisions of Articles 9, paragraph 2, letter b), and 88 of the Regulation; on the role of the employer and the competent doctor, also in light of the emergency regulatory framework, guidance document of May 14, 2021, web doc. no. 9585367).

Even in the exceptional emergency situation, considering the issues arising from the pressing need to protect workplace safety and the related processing of personal data, employers must therefore operate within the scope and limits provided by the applicable regulations, which constitute the legal basis for the related processing, avoiding undertaking initiatives not provided for by law - including the specific provisions introduced during the emergency period and in the safety protocols for workplaces - with possible harmful effects for the data subjects in the work and professional context. In this framework, in the absence of express regulatory provisions, it is therefore not permitted for the employer to collect and process, directly from the data subjects or, as in the present case, from other sources, personal data even related to the health status of the worker (see, these principles have been reiterated in numerous provisions adopted in the pandemic context, starting from the FAQs on “Data processing in the public and private workplace during the health emergency,” web doc. no. 9337010 and more recently with provision of May 26, 2022, No. 195, web doc. no. 9788986, although in relation to issues different from those subject to this provision).

No emergency provision has instead provided for the possibility of knowing such information through the health dossier which, as already highlighted, is an optional informational tool and, by its nature, incomplete, that can be used exclusively for the care purposes of the individual concerned. Additionally, it should be noted that, according to what has been stated in the documents, the complainant had nonetheless communicated her positive status to the nursing coordinator precisely to

facilitate the organization of work in the department, a circumstance that highlights the irrelevance of the defensive arguments aimed at justifying the aforementioned access to the dossier, in the manner described above, for the alleged purposes of managing and organizing work shifts.

The use of the health dossier carried out by the Company during the pandemic period has, instead, allowed access to the claimant's dossier for purposes other than care, namely to "know what human resources we can count on to carry out our work and care for patients in the best possible way." This choice, according to what has been represented in the documents, would have been made considering that access to the health dossier was "the quickest method to know the outcome of the TNF" (nasopharyngeal swab) for Covid-19 present in the health dossier of colleagues and therefore also of the claimant (cf. cited notes).

From the statements made in the documents by the authors of the accesses to the claimant's dossier that are being contested, which have been reported by the Company, it is established that these accesses did not occur for care purposes, but rather for organizational/administrative purposes related to the management of hospital shifts and the evaluation of services provided to patients affected by Covid-19.

Although the Company acted out of the need to quickly organize the hospital shifts of healthcare personnel, also considering the potential absenteeism rate due to employee illness and that this activity was characterized by particular complexity given the delicate situation related to the pandemic context, it should have treated the claimant's data in compliance with the aforementioned sector regulations that constitute its legal basis and establish limits and prerequisites.

This is also in respect of the principle of purpose limitation according to which the health dossier can only be used by healthcare personnel who are caring for the individual, being understood as a tool to facilitate the care pathway of the latter, and not instead for the aforementioned organizational needs - illustrated in the documents - that can be pursued with the typical tools that the employer possesses for the management of personnel and their presence in service. It emerges, in fact, from the statements of the claimant and the Company that Ms. XX had not been taken in charge by the structure that carried out the accesses; this is evident as the authors of the accesses, not having the claimant as a patient, had to make a self-declaration to be able to consult her dossier.

Moreover, the optional nature of the health dossier and the incomplete information, dictated by the possibility that the individual may exercise the right to obscurity over some of the information collected through the dossier (including Covid-19 reports) and by the circumstance that this tool does not contain reports issued by other healthcare structures, render the dossier an inadequate means to effectively carry out the organizational and administrative activities that the Company can, instead, perform in compliance with the specific and different regulatory framework of the sector.

It is therefore noted that in this case, the use of the health dossier to manage the organization of the shifts of healthcare personnel not only does not fall within the purposes of the health dossier itself, but also proves to be an ineffective method as this tool is not only bound, as stated, to the consent of the individual, but is also, by its nature, incomplete, as the individual can exercise the right to obscurity over data and documents including the results of Covid tests, or not containing health information related to healthcare services provided by other healthcare structures.

Additionally, as highlighted multiple times by the Guarantor also in the cited guidelines and in other provisions (cf. provision of April 21, 2021, n. 155), the data controller must identify, in relation to the different functions assigned to the personnel, organizational technical solutions that allow those performing organizational and administrative tasks, such as the management of hospital shifts or the evaluation of the assistance provided, to access, within the limits of the attributions provided by law, a more complete information base than that present in the company health dossier.

It is also noted that the performance of tasks of public interest in the public health sector, referred to by the Company, cannot be considered as legitimizing the aforementioned processing of the claimant's health data through the health dossier (which was constituted, among other things, without the required consent), as it is in contrast with the provisions on the protection of personal data that were

adopted during the pandemic period and which provide that processing must occur in compliance with the general principles of processing, among which are those of lawfulness, transparency, fairness, purpose limitation, and data minimization (art. 5, par. 1, lett. a), b) and c) of the Regulation).

2.3 Access tracking systems and operations performed and alert systems

It is also represented that in the aforementioned Guidelines, the Authority has deemed that "the data controller must implement systems for controlling access to the database and for detecting any anomalies that may constitute unlawful processing, through the use of anomaly indicators (so-called alerts) useful for guiding subsequent audit interventions. The data controller must therefore envisage the activation of specific alerts that identify anomalous or at-risk behaviors related to the operations performed by those authorized to process data (e.g., related to the number of accesses made, the type or the time frame of the same)."

In the same Guidelines, this Authority has...

highlighted expressly that, in the creation of the health dossier, the holder must adopt control systems for the operations carried out on the dossier, through procedures that provide for the automatic registration in specific log files of accesses and operations performed. In particular, the log files must record for each access operation to the dossier carried out, at least the following information: the identification code of the authorized person who performed the access operation; the date and time of execution; the code of the workstation used; the identifier of the patient whose dossier is affected by the access operation by the authorized person and the type of operation performed on the data.

Due to the particular sensitivity of the processing of personal data carried out through the dossier, it is necessary that even simple consultation operations (inquiry) are tracked. The configuration of the health dossier carried out by the Company in the emergency context did not, however, foresee, by express acknowledgment of the same in the documentation on file, that accesses to the health dossier by "all those healthcare professionals who during the indicated period (2019/2020) were authorized to access the operational units in which (...) (the complainant) transited" (note of XX - prot. n. XX) would be tracked.

In this regard, it is noted that, contrary to what is indicated in the aforementioned Guidelines, the documentation attached to the defensive writings does not currently provide for the registration of all operations carried out on the health dossier, nor a control system for all types of accesses to the dossier.

3. Conclusions.

In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation - and considering that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor" - it is represented that the elements provided by the data controller in the defensive memoranda related to the aforementioned proceedings do not allow overcoming the observations notified by the Office with the acts initiating the proceedings for the adoption of corrective and sanctioning measures, nor does any of the cases provided for by Article 11 of the Guarantor Regulation No. 1/2019 apply.

The use of the complainant's health dossier has resulted, as highlighted above, in unlawful data processing as it was carried out for purposes other than those of care that can be pursued through the health dossier, as well as by subjects who were not involved in the complainant's care pathway and, therefore, in violation of the principles of lawfulness and purpose limitation (Article 5, paragraph 1, letters a) and b) of the Regulation).

In addition to violating the principle of lawfulness, such processing also occurred in violation of the principles of transparency, fairness, and data minimization as, under the sector regulatory framework, those responsible for organizing hospital shifts and verifying the quality of care provided, although

healthcare professionals, should not have accessed the health documentation of colleagues in pursuit of such specific and distinct purposes, but only the information related to the absence from service of colleagues strictly necessary for the fulfillment of their tasks, without knowing the clinical and diagnostic details related (Article 5, paragraph 1, letters a) and c) of the Regulation).

It is also noted that a specific and explicit manifestation of will should have been obtained, as indicated by the aforementioned Company, also with reference to the processing of the complainant's personal data carried out within the so-called "TeleCovid Zcare program," which does not appear to have been obtained.

Considering what has been stated in the documents, it does not appear that the Company has provided a system for detecting any anomalies that could constitute unlawful processing, or the use of anomaly indicators (so-called alerts) aimed at identifying abnormal or risky behaviors related to the operations performed by authorized processing subjects (e.g., number of accesses performed, type or time frame of the same), useful for guiding subsequent audit interventions in violation of the principles of integrity and confidentiality of personal data (Article 5, paragraph 1, letter f) of the Regulation).

The elements described above have made it possible for colleagues of the complainant to access her health dossier for purposes other than those of care and specifically related to the organization of hospital shifts and the evaluation of the quality of care provided concerning Covid-19, in the absence of the explicit and specific consent of the interested party, and, therefore, of any legal basis.

In this context, considering the above observations and in particular that not all operations performed on the dossier are recorded but only "the most significant" and that only accesses to so-called "non-assigned" patients are monitored, it is deemed necessary to order the aforementioned Company, pursuant to Article 58, paragraph 2, letter d), of the Regulation, the following corrective measures, to be adopted within 90 days from the adoption of this document.

provision, through the implementation for all types of access to the dossier:

of systems for monitoring the database and for detecting any anomalies that may constitute unlawful processing, through the use of anomaly indicators (so-called alerts) useful for guiding subsequent audit interventions;

of systems for controlling the operations performed on the dossier, through procedures that provide for the automatic registration in appropriate log files of all accesses and operations carried out (including even simple consultation (inquiry)), with at least the following information: the identification code of the authorized subject who carried out the access operation; the date and time of execution; the code of the workstation used; the identifier of the patient whose dossier is affected by the access operation by the authorized person and the type of operation performed on the data.

4. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (arts. 58, par. 2, lett. i and 83 of the Regulation; art. 166, comma 7, of the Code). The violation of arts. 5, par. 1, lett. a), b), c) and f), 9, and 32 of the Regulation, caused by the conduct of the Local Health Authority of Lodi, is subject to the application of the administrative pecuniary sanction pursuant to art. 83, par. 4 and 5, of the Regulation.

It should be noted that the Guarantor, pursuant to arts. 58, par. 2, lett. i) and 83 of the Regulation, as well as art. 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to article 83, in addition to [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case" and, in this context, "the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to article 166, comma 7, of the Code" (art. 16, comma 1, of the Guarantor's Regulation no. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, indicated in art. 83, par. 1, of the Regulation, in light of the elements provided for in art. 85, par. 2, of the Regulation in relation to which it is observed that for both proceedings:

- the Authority became aware of the event following a complaint (art. 83, par. 2, lett. h) of the

Regulation);

- the unlawful accesses concerned the health dossier of a patient who was also an employee of the Authority by healthcare professionals who were her colleagues and who were not involved in her care process (art. 83, par. 2, lett. a) and b) of the Regulation);
- the configuration of the health dossier carried out by the Authority effectively allowed the aforementioned healthcare professionals to access the health dossier of a patient who was their colleague without being authorized and without alerts or monitoring systems in place to signal such unlawful conduct (art. 83, par. 2, lett. d) of the Regulation);
- the processing occurred during the pandemic period that exceptionally involved the aforementioned Authority (art. 83, par. 2, lett. a) of the Regulation);
- the owner cooperated during the investigation by adopting new procedures and organizational measures to be followed by its employees, in compliance with the applicable regulatory framework and in line with the Guarantor's indications for processing in the healthcare and workplace sectors (art. 83, par. 2, lett. f) of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the pecuniary sanction provided for by art. 83, par. 5, lett. a) of the Regulation, for the violation of arts. 5, par. 1, lett. a), b), c) and f), 9, and 32 of the Regulation in the amount of 40,000 (forty thousand) for the proceeding initiated following the complaint as an administrative pecuniary sanction deemed, pursuant to art. 83, par. 1, of the Regulation, effective, proportionate, and deterrent. It is also considered that the accessory sanction of publication on the Guarantor's website of this provision, provided for by art. 166, comma 7 of the Code and art. 16 of the Guarantor's Regulation no. 1/2019, should be applied, also considering the type of personal data subject to unlawful processing. Finally, it is noted that the conditions referred to in art. 17 of Regulation no. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

ALL OF THE ABOVE HAVING BEEN STATED, THE GUARANTOR

declares the unlawfulness of the processing of personal data carried out, in both proceedings described, by the Local Health Authority of Lodi, for the violation of arts. 5, par. 1, lett. a), b), c) and f), 9, and 32 of the Regulation as stated in the reasoning.

ORDERS

pursuant to arts. 58, par. 2, lett. i) and 83 of the Regulation, as well as art. 166 of the Code, the Local Health Authority of Lodi CF 09322180960, to pay the sum of 40,000 euros (forty thousand) as an administrative pecuniary sanction for the aforementioned violations according to the methods indicated in the annex, within 30 days from the notification in reasoning; it is represented that the ****Violator****, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within 30 days, an amount equal to half of the imposed sanctions.

****ORDERS****

the aforementioned Company:

1. in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sums of €40,000 (forty thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/1981;
2. pursuant to Article 58, paragraph 2, letter d), of the Regulation, within 90 days from the notification of this provision, to implement for all types of access to the dossier:
 - a. systems for monitoring the database and for detecting any anomalies that may constitute unlawful processing, through the use of anomaly indicators (so-called alerts) useful for guiding subsequent audit interventions;
 - b. systems for controlling the operations performed on the dossier, through procedures that provide for the automatic recording in appropriate log files of all accesses and operations carried out (including simple consultation (inquiry)), with at least the following information: the identification code of the authorized subject who carried out the access operation; the date and time of execution; the code of

the workstation used; the identifier of the patient whose dossier is affected by the access operation by the appointed person and the type of operation performed on the data.

Regarding the previous point 2, the aforementioned company is requested to communicate what initiatives have been undertaken in order to implement the above injunction with this provision and to provide adequately documented feedback, pursuant to Article 157 of the Code, within 20 days from the expiration of the above-mentioned deadline; any failure to respond may result in the application of the administrative pecuniary sanction provided for by Article 83, paragraph 5, of the Regulation.

****DECIDES****

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the website of the Guarantor and considers that the conditions set forth in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to file an appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, October 12, 2023

THE PRESIDENT

Stanziome

THE RAPPORTEUR

Stanzione

THE SECRETARY GENERAL

Mattei